

Automated AWS Security Group Compliance Checker

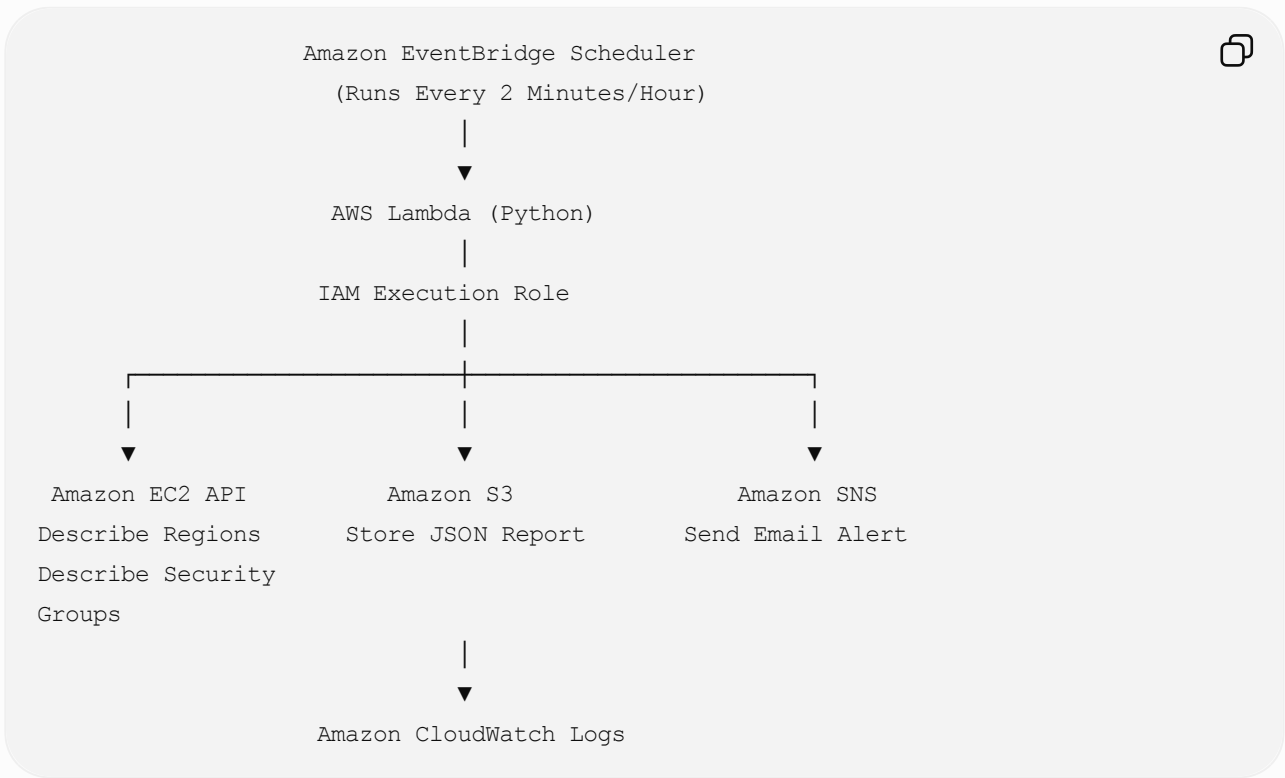
Project Overview

Objective

Develop a serverless AWS solution that automatically scans all AWS Regions for Security Groups with unrestricted inbound access (`0.0.0.0/0`), stores the scan results in Amazon S3, and sends an email notification using Amazon SNS.

The solution is completely automated using Amazon EventBridge Scheduler and AWS Lambda.

Architecture



AWS Services Used

AWS Service	Purpose
EventBridge Scheduler	Automatically triggers Lambda
AWS Lambda	Executes the Python code

AWS Service	Purpose
IAM Role	Grants required AWS permissions
Amazon EC2	Retrieves Security Group details
Amazon SNS	Sends email notifications
Amazon S3	Stores audit reports
Amazon CloudWatch Logs	Stores execution logs

Prerequisites

Before creating the solution, create the following AWS resources:

- Amazon S3 Bucket
- Amazon SNS Topic
- IAM Role
- Lambda Function
- EventBridge Scheduler

Step 1: Create an Amazon S3 Bucket

Navigate to:

```
AWS Console
→ Amazon S3
→ Create Bucket
```



Example

```
Bucket Name

sgfindrules
```



Purpose

- Store Security Group compliance reports
- Reports are stored in JSON format

Step 2: Create an Amazon SNS Topic

Navigate to

AWS Console
→ Amazon SNS
→ Topics
→ Create Topic



Configuration

Type

Standard

Topic Name

SGfindTopic



Create an Email Subscription.

SNS Topic

↓

Create Subscription

↓

Protocol

Email

↓

Enter Email Address

↓

Confirm Subscription



Purpose

Whenever insecure Security Groups are found, an email notification is sent.

Step 3: Create an IAM Role

Navigate to

AWS Console



↓

IAM

↓

Roles

↓

Create Role

Trusted Entity

AWS Service



↓

Lambda

Role Name

Lambda-SecurityGroupAuditRole



IAM Permissions

Attach the following policy.

</> JSON



```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "ec2:DescribeRegions",
        "ec2:DescribeSecurityGroups"
      ],
      "Resource": "*"
    }
  ],
}
```

```

{
  "Effect": "Allow",
  "Action": [
    "sns:Publish"
  ],
  "Resource": "arn:aws:sns:us-east-1:501894534118:SGfindTopic"
},

{
  "Effect": "Allow",
  "Action": [
    "s3:PutObject"
  ],
  "Resource": "arn:aws:s3:::sgfindrules/*"
},

{
  "Effect": "Allow",
  "Action": [
    "logs:CreateLogGroup",
    "logs:CreateLogStream",
    "logs:PutLogEvents"
  ],
  "Resource": "*"
}

]
}

```

Purpose

Permission	Purpose
ec2:DescribeRegions	Retrieve all AWS Regions
ec2:DescribeSecurityGroups	Retrieve Security Groups
s3:PutObject	Upload reports to S3
sns:Publish	Send email notifications
CloudWatch Logs	Store Lambda execution logs

Step 4: Create the Lambda Function

Navigate to

AWS Console



↓

Lambda

↓

Create Function

Configuration

Function Name



SecurityGroupComplianceAudit

Runtime

Python 3.13

Architecture

x86_64

Execution Role

Lambda-SecurityGroupAuditRole

Click

Create Function



Step 5: Upload the Python Code

Paste the Python script into the Lambda function.

The code performs the following actions:

1. Connects to EC2.
2. Retrieves all AWS Regions.
3. Loops through every Region.
4. Retrieves all Security Groups.
5. Checks inbound rules.
6. Detects Security Groups allowing:



7. Stores findings in a list.
8. Sends an SNS email notification.
9. Uploads the JSON report to Amazon S3.

Python Workflow

Lambda Starts



|



Create EC2 Client

|



Retrieve AWS Regions

|



Loop Through Each Region

|



Describe Security Groups

|



Read Inbound Rules

|



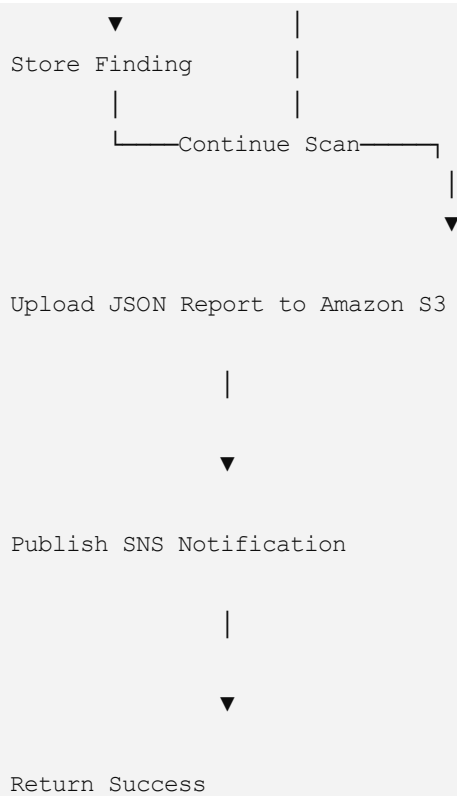
Is CIDR = 0.0.0.0/0 ?

Yes

No

|

|



Step 6: Create an EventBridge Scheduler

Navigate to

Amazon EventBridge

↓

Scheduler

↓

Create Schedule

Configuration

Schedule Name

SecurityGroupAuditScheduler

For Testing

`cron(* / 2 * * * ? *)`

Runs every **2 minutes**.

For Production

```
cron(0 * * * ? *)
```



Runs every **1 hour**.

Target

AWS Lambda



↓

SecurityGroupComplianceAudit

Click

Create Schedule



Step 7: Test the Solution

You can either:

- Click **Test** in the Lambda Console.
- Wait for the EventBridge Scheduler to invoke the Lambda automatically.

Step 8: Verify the Results

Amazon CloudWatch Logs

Navigate to

Lambda



↓

Monitor

↓

View CloudWatch Logs

or

CloudWatch



↓

Log Groups

↓

/aws/lambda/SecurityGroupComplianceAudit

Verify the Lambda executed successfully.

Amazon S3

Open the bucket

sgfindrules



Expected output

security-audit-2026-07-15-10-30-05.json



Example report

JSON



```
[
  {
    "Region": "us-east-1",
    "SecurityGroupId": "sg-0123456789abcdef",
    "Port": 22,
    "Protocol": "tcp"
  }
]
```

Amazon SNS

Check your email.

Example

Subject



The email contains the Security Groups that allow unrestricted inbound access.

Monitoring

Monitor the Lambda execution from:

Lambda



↓

Monitor

Metrics include:

- Invocations
 - Errors
 - Duration
 - Throttles
-

Monitor detailed logs from:

CloudWatch



↓

Log Groups

↓

/aws/lambda/SecurityGroupComplianceAudit

Project Outcome

This solution automatically:

- Discovers all AWS Regions.
- Scans every Security Group.
- Detects unrestricted inbound rules (0.0.0.0/0).
- Generates a compliance report.
- Stores the report in Amazon S3.
- Sends an email notification through Amazon SNS.

- Records execution logs in CloudWatch.
-

Skills Demonstrated

- AWS Lambda
 - Python (Boto3)
 - Amazon EventBridge Scheduler
 - IAM Roles and Policies
 - Amazon EC2 API
 - Amazon SNS
 - Amazon S3
 - Amazon CloudWatch Logs
 - AWS Security
 - Serverless Architecture
 - Infrastructure Automation
-

Future Enhancements

- Detect IPv6 (`::/0`) rules.
 - Filter only sensitive ports (22, 3389, 3306, 5432, etc.).
 - Generate CSV and HTML reports.
 - Upload reports to a timestamped folder structure in S3.
 - Publish CloudWatch custom metrics.
 - Support scanning multiple AWS accounts using AWS STS AssumeRole.
 - Trigger remediation automatically (for example, remove unauthorized rules after approval).
-

Resume Description

Developed a serverless AWS security compliance solution using Amazon EventBridge Scheduler, AWS Lambda (Python), IAM, EC2, Amazon SNS, Amazon S3, and CloudWatch Logs. The solution automatically scans all AWS Regions for Security Groups with unrestricted inbound access (`0.0.0.0/0`), generates JSON compliance reports, stores them in Amazon S3, and sends automated email notifications via Amazon SNS. Implemented using Boto3 with least-privilege IAM permissions and fully automated scheduling.

